



File No.: EXP202209077

RESOLUTION OF RECOURSE FOR RECONSIDERATION

Examined the recourse for reconsideration filed by ALL ABOUT WATER, S.L. (hereinafter, the appellant), against the resolution issued by the Director of the Spanish Agency for Data Protection, dated September 26, 2024, and based on the following

FACTS

FIRST: On September 26, 2024, a resolution was issued by the Director of the Spanish Agency for Data Protection, in file EXP202209077, by virtue of which ALL ABOUT WATER, S.L. was imposed a fine of 5,000 euros for the infringement of Article 5.1.f) of the GDPR, classified according to the provisions of Article 83.5 of the GDPR as very serious for the purposes of prescription, in Article 72.1 a) of the LOPDGDD, for the infringement of Article 32 of the GDPR, classified according to the provisions of Article 83.4 of the GDPR as serious for the purposes of prescription, in Article 73 f) of the LOPDGDD, a fine of 3,000 euros, and it was ordered that, pursuant to Article 58.2.d) of the GDPR, within 1 month from the date the resolution became final and enforceable, it must prove that it has implemented the necessary corrective measures to adapt its actions to the personal data protection regulations, preventing similar events from occurring in the future, as well as to inform this Agency, within the same period, about the measures adopted.

This resolution, which was notified to the appellant on September 27, 2024, was issued following the processing of the corresponding sanctioning procedure, in accordance with the provisions of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (LOPDGDD), and supplementary to Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), regarding the processing of sanctioning procedures.

SECOND: As proven facts of the aforementioned sanctioning procedure, PS/00265/2023, the following was recorded:

“FIRST: There is a communication sent from the email address of the entity being claimed (support@thebath.zendesk.com) addressed to a third party with a copy to the claimant, which contains a thread informing them, among other things, that request number ***REFERENCE.1 was closed and merged into request number ***REFERENCE.2. This thread contains information about the order made by the claimant and includes identifying data of the claimant (name and surname) and contact data (telephone number and postal address).

SECOND: On July 15, 2022, it is recorded that the claimant communicated the following:

“Good afternoon, I do not understand why you have merged my request ***REFERENCE.1 of order ***REFERENCE.3 with this other one that has nothing to do with me. You have resolved the other one and I cannot add any comments... My personal data that appears here has been made available to a third party that has nothing to do with the case and seriously violates data protection law. I request that you take action immediately.”

THIRD: It is verified that 11 minutes later the entity responded with the following:

“We have proceeded to resolve it. We are sorry. Best regards.”

FOURTH: The entity being claimed indicates that on the same day, July 15, it proceeded to remove the CC (Carbon Copy) from the communications so that no ticket would be received by both users.

FIFTH: The entity being claimed submits a written statement in which it acknowledges that the incident occurred and that it took measures to safeguard its client's data within no more than eleven minutes.”

THIRD: The appellant filed, on October 24, 2024, a recourse for reconsideration with this Spanish Agency for Data Protection, in which, in summary, it states that this is not a matter of great magnitude to warrant prior investigations, therefore, it is not proven at any time the delay on the part of the Spanish Agency for Data Protection to inform about the fact subject to the complaint.

It considers that the correct action would have been to declare the expiration of the procedure, but, in order to maintain a collaborative attitude with the Agency, it responded to the request, acknowledging

the facts and indicating the measures to be taken to prevent a recurrence.

It considers that this constitutes a clear violation of the fundamental right enshrined in the Spanish Constitution.

It states that 3 months later, in March 2023, the Agency made an "Open" request for it to provide supporting information and documentation that proves compliance and controls of security measures it carries out, without specifying what exactly the Agency requires, when it is aware that the responses to the requests are being handled internally by the company, observing a lack of understanding, which is true does not exempt from compliance in legal terms, but this party understands that the information could have been requested in a more accessible language for the company.

Once the company proceeded to respond to the request 8 months later, in November 2023, the Agency communicated to the company the agreement to initiate sanctioning proceedings, 1 year and 4 months after the initiation of the file and the date of the events. A period much longer than that established by Article 64 LOPDPD.

It considers that, in this case, the elapsed time was 20 months, almost double that established by the Law.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/10

In addition to all that has been indicated, it states that the Spanish Agency for Data Protection indicates in its proposal for resolution that, since it concerns a very serious sanction, the statute of limitations is 3 years, which shows that it is aware of the existence of the expiration of said procedure, proceeding to classify the sanction as very serious, in order to be able to rely on the legally established period of 3 years.

It argues that to classify the sanction as very serious does not correspond with the criteria set forth in Article 71 of the LOPDGDD, since it establishes d) The use of data for a purpose that is not compatible with the purpose for which it was collected, without the consent of the affected party or a legal basis for it. This is not reflected here, as the data controller has at all times acknowledged its security breach, since, as recorded in the proceedings, it is a digitized method for customer claims, the only thing done manually is the entry of a number to unify the reports opened by the same customer. The Agency has never disputed the nature of the facts and has never classified the infringement as an incorrect use of the data, but rather as a leakage of information due to human error. Likewise, it has not been proven at any time that a third party was actually aware of the affected party's data.

It alleges that the Agency has requested that the existence of documents proving compliance with the LOPDGDD be accredited, and this has been provided, just as the measures to be taken by the data processor have been provided, the measures to be implemented to prevent it from happening again, always speaking of the SECURITY BREACH suffered by the company, as it is an isolated, specific incident that occurred due to a mistake with a number, but at NO time were the affected party's data made available to a third party.

It finds the sanction to be disproportionate, as established in Article 74 m) The incomplete, late, or defective notification to the data protection authority of information related to a personal data security breach in accordance with the provisions of Article 33 of Regulation (EU) 2016/679. It is classified as a MINOR infringement, which brings us back to the point of expiration, since MINOR infringements expire one year after the facts occurred. In this case, 2 years have passed.

It also highlights that when responding to the request from November 2023, contact details of a professional in the field were established, which have been overlooked, and what was communicated to the company was that there would be a change in the person who would carry out the present procedure. Likewise, it indicates that a series of documentation is provided that is nowhere to be seen, which leads us to believe that this has been an error on the part of the administration, since, as can be seen in the acknowledgment of receipt attached as DOCUMENT 1, the files mentioned are attached, and this is evidenced in the receipt.

It informs that in the documentation that was attached, the measures taken by the company with the

intention of remedying the error committed can be observed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/10

Finally, it is alleged that the security breach that occurred was reported to the Agency, and that measures have been taken to ensure that it will not happen again, as can be verified in the documentation provided.

LEGAL GROUNDS

I

Jurisdiction

The Presidency of the Spanish Agency for Data Protection is competent to resolve this appeal, in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and Article 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD).

II

On the optional appeal for reconsideration filed

In relation to the statements made by the appellant, the allegations already presented throughout the sanctioning procedure are basically reiterated. It should be noted that all of them have already been analyzed and dismissed in the Legal Grounds of the contested resolution, the content of which is fully reproduced herein.

Regarding the necessity of the preliminary investigative actions, Article 67 of the LOPDGDD establishes:

1. Before the adoption of the agreement to initiate the procedure, and once the complaint has been admitted for processing, if applicable, the Spanish Agency for Data Protection may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances that justify the processing of the procedure. The Spanish Agency for Data Protection will act in any case when the investigation of treatments involving massive traffic of personal data is necessary.

2. The preliminary investigative actions shall be subject to the provisions of section 2 of chapter I of title VII of this organic law and may not exceed a duration of eighteen months from the date of the admission agreement or from the date of the agreement deciding its initiation when the Spanish Agency for Data Protection acts on its own initiative.

From this regulation, it is not inferred in any way that the AEPD must justify the initiation of preliminary actions in the manner required by the appellant. The preliminary investigative actions are carried out to clarify the facts and circumstances of what happened, gathering more information in order to determine whether or not there is a possible infringement of data protection regulations.

In this sense, the initiation of preliminary investigations and their execution, a power of the AEPD, with or without complaints, does not prejudice anything, but allows for the gathering of necessary information to determine if there are indications of infringement. Even after such investigation, it may be that the actions are archived because, based on the information gathered, it is understood that there are no indications of infringement. This has not happened in the present case.

What the regulation does indicate is that, after the submission of complaints, this Agency must decide whether to admit them for processing or not. In this case, considering the aforementioned, on October 15, 2022, it was communicated that your complaint had been admitted for processing after three months had elapsed since it was filed with the AEPD. And, as indicated in Article 67.2 LOPDGDD referenced, the AEPD may carry out preliminary investigative actions in order to achieve a better determination of the facts and circumstances. It is a power attributed to it by the GDPR and by the LOPDGDD.

On the other hand, it should be noted that the statute of limitations for this procedure is computed from the date on which its initiation is agreed, that is, from October 6, 2023, making it inappropriate to add

any other period to this computation, for the purposes of measuring the duration of the administrative file, such as the time of the preliminary investigative actions, or the time that elapses between the conclusion of those actions and the opening of the procedure, nor the time corresponding to the admission phase of the complaints filed.

This has been repeatedly stated by our Supreme Court. In the Judgment of 21/10/2015, the Judgment of 26/12/2007 (appeal 1907/2005) is cited, which declares the following:

"[...] the time of the procedure [...] is counted from the initiation of the sanctioning file, which obviously excludes from the computation the time of the reserved information"; "[...] the greater or lesser duration of the preliminary phase does not entail the expiration of the subsequent procedure."

Also in the Judgment of the Supreme Court of 13/10/2011 (appeal 3987/2008) that examines a ground for cassation relating to the computation of the statute of limitations of the procedure, it is declared as follows:

"We cannot share the reasoning presented by the lower court to set a different starting point than that established by the Law, indicating as the initial date for computation the day after the conclusion of the preliminary informative proceedings.

[...]

Well, once those preliminary actions have been carried out, the time it takes the Administration to agree to initiate the procedure [...] may have the consequences that apply regarding the computation of the prescription (extinction of the right); but it cannot be taken into consideration for the purposes of expiration, since this figure aims to ensure that once the procedure is initiated, the Administration does not exceed the time limit it has to resolve. In the grounds

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/10

Third, the court of first instance interprets the norm in a manner that is not in accordance with the nature of the institution of expiration, since, unlike prescription, which is a cause for the extinction of the right or responsibility in question, expiration is a means of terminating the procedure due to the passage of the time limit set by the norm. Therefore, its assessment does not prevent, if the established time limit for the prescription of the action for the restoration of urban legality by the Administration has not elapsed, the initiation of a new procedure.

Thus, the argument presented by the appellant on this matter in their allegations does not conform to the law.

Regarding the prescription of the infringements attributable to the appellant for the violation of Articles 5.1.f) and 32 of the GDPR, it should be noted that it is closely linked to the legal qualification of the facts already assessed, a matter that was already analyzed in the Legal Grounds of the contested resolution, the content of which is considered to be fully reproduced.

On the other hand, it is appropriate to recall that the GDPR introduces the principle of proactive responsibility as a fundamental element of compliance with its provisions, with this obligation resting on the data controller. As established by Article 24 of this regulation, it is the responsibility of the data controller to apply appropriate technical and organizational measures to ensure that the processing is in accordance with the GDPR, or, in the terms of Recital 74 of the same regulation: "In particular, the controller should be obliged to implement appropriate and effective measures and should be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures."

The text of the resolution establishes what the infringements committed have been and the facts that have led to the violation of data protection regulations, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, since it is the data controller who fully knows their organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

This Agency is not obliged to issue any opinion or assessment regarding the compliance with data

protection regulations of the processing carried out by a controller at their request, except in the case of prior consultation provided for in Article 36, a situation that we do not find ourselves in within the present procedure. On the other hand, although this Agency has various channels for controllers to raise their doubts, the reports that may be issued through such channels are not binding, so the absence of an opinion from the AEPD regarding the controller's processing cannot justify the non-compliance with their obligations.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/10

It must therefore be concluded that the appellant has been able to exercise their right to defense at all times throughout the proceedings of the sanctioning procedure, being aware at all times of the facts attributed to them and the infringements arising from them, and that the rejection by this AEPD of the arguments repeatedly put forward, based on duly reasoned considerations, cannot be interpreted as a lack of understanding of what is stated, as alleged by the appellant.

As a general and final consideration, it should be noted that none of the sanctions imposed violate the principle of proportionality.

Thus, it should be recalled that Articles 83.4 and 83.5 of the GDPR, where the infringement of Article 32 and that of Article 5.1.f) are respectively classified, establish limits on the amounts of fines that can be imposed that are far removed from those that have ultimately been established, having considered for their individualization, within the legally established margins, the specific circumstances present in this case.

This adjustment of the sanction to the specific case not only does not violate the principle of proportionality, but, as will be indicated below, is required to ensure proper compliance with it.

As the Supreme Court has considered in various rulings (STS 4th July 10, 1985, STS December 12, 2012, STS 3rd June 23, 2014), the discretion granted to the Administration in the imposition of sanctions, within the legally established limits, must be exercised by weighing the concurrent circumstances, in order to achieve the necessary and due proportion between the facts attributed and the responsibility required, given that every sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality.

For its part, Article 29 of Law 40/2015 of October 1, on the Legal Regime of the Public Sector, in paragraph 3, also refers to the need to adjust sanctions to the severity of the facts constituting the infringement.

Consequently, the Administration has a certain margin of appreciation of the specific circumstances when assessing the scope of the infringement, which is necessary and required to determine the specific amount of the sanction, which does not imply that in its actions one can speak of discretion in the strict sense or arbitrariness.

On this particular matter, the ruling of the Supreme Court of December 12, 2012, rec. 5120/2009, which reproduces what was already expressed in its ruling of June 29, 2010, clarifies the following: "But it is a legal error to understand that such a margin of appreciation can be properly qualified as discretion, in its strict sense of admitting a more or less broad freedom to decide one sanction or another. This margin of appreciation means that it is the Administration that is in a better position to assess the relative weight of the various concurrent circumstances in a specific case when determining the risk created to security or the harm caused to the protected legal asset. But this capacity for appreciation does not mean that the relevant circumstances should not be taken into account."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/10

"the various concurrent circumstances must be taken into account to determine a sanction and thus be made evident in any sanctioning resolution."

The discretion that the Administration has to determine the sanction to be imposed is quite limited, with all elements to be considered for determining the amount of the corresponding fine being clearly regulated.

That is to say, without prejudice to the existence of the indicated margin of appreciation, the Administration must adjust its actions to the application of evaluative criteria provided for in the regulation and inferable from integrative principles of the legal system (Supreme Court Judgment of November 30, 2004, Rec. No. 6573/2001 (RJ 2005\5402).

In the case at hand, these evaluative criteria are set forth in Article 83.2 of the GDPR and in Article 76.2 of the LOPDPGDD, and the specific determination of the sanctions has been made taking into account the concurrence of the circumstances provided for in the aforementioned provisions for the graduation of the sanctions, which have been exposed and reasoned throughout this sanctioning procedure, without it being accepted that there has been a violation of the principle of proportionality by this Agency in the sense alleged by the appellant.

Therefore, the allegations must be dismissed, noting that the arguments presented do not undermine the essential content of the infractions declared to have been committed nor do they constitute sufficient grounds for justification or exculpation.

III

Conclusion

Consequently, in the present appeal for reconsideration, the appellant has not provided new facts or legal arguments that would allow for a reconsideration of the validity of the contested resolution.

IV

Late Resolution

Due to reasons related to the functioning of the administrative body, therefore not attributable to the appellant, as of this date, the mandatory pronouncement of this Agency regarding the present appeal has not been issued.

In accordance with the provisions of Article 24 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), the effect of administrative silence in the procedures for challenging acts and provisions is dismissive.

Nevertheless, and despite the time that has passed, the Administration is obliged to issue an express resolution and to notify it in all procedures, regardless of their initiation form, as provided in Article 21.1 of the aforementioned LPACAP.

Therefore, it is appropriate to issue the resolution that concludes the procedure of the appeal for reconsideration filed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/10

In view of the cited provisions and other generally applicable regulations, the Presidency of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DISMISS the appeal for reconsideration filed by ALL ABOUT WATER, S.L. against the resolution of this Spanish Agency for Data Protection, issued on September 26, 2024, in file EXP202209077.

SECOND: TO NOTIFY this resolution to ALL ABOUT WATER, S.L.

THIRD: To warn the sanctioned party that the imposed sanction must be fulfilled once this resolution is notified, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, within the voluntary payment period indicated in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by depositing it into the restricted account No. ES00 0000 0000 0000 0000 0000, opened in the name of the Spanish Agency for Data Protection, at CAIXABANK, S.A., or otherwise, collection will proceed in the executive period.

If the date of notification falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day, and if it falls

between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned LPACAP. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it would consider the provisional suspension to be concluded.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/10

180-020125

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es